

Segurança da Informação & Consultoria Web3

Relatório de Auditoria de Segurança

Resumo Executivo Consolidado

Cliente	AxiaDigitalSolutions
Preparado por	HeimdallSec
Data	24/07/2026
Versão do Documento	2.1
Status da Auditoria	Final (correções aplicadas; itens informativos pendentes)

Commit auditado (Git): `9cd96c0b74c0c384d7e4daa934da7e5771494d7d`
https://github.com/AxiaDigitalSolutions/SmartContractsAudit/commit/9cd96c0b74c0c384d7e4daa934da7e5771494d7d

DOCUMENTO CONFIDENCIAL

Sumário

Sumário 2
1. Sumário Executivo 3
2. Postura de Risco Consolidada 3
3. Escopo Auditado 3
4. Consolidação das Descobertas por Artefato 4
5. Itens em Aberto e Principais Remediações 4
  5.1 Itens em Aberto (Informational / Gas) 4
  5.2 Principais Remediações Aplicadas 4
6. Conclusão 5
7. Termo de Isenção de Responsabilidade (Disclaimer) 5

1. Sumário Executivo

A HeimdallSec conduziu, para a **AxiaDigitalSolutions**, um ciclo de auditorias de segurança sobre o conjunto de contratos inteligentes e interfaces que compõem a plataforma de tokenização de ativos da Axia. Este documento consolida, em linguagem executiva, os resultados dos **6 relatórios técnicos individuais** produzidos ao longo do engajamento, oferecendo à liderança uma visão única da postura de segurança do projeto e do estágio de remediação.

O trabalho abrangeu contratos de token (padrões ERC-721, ERC-20 e ERC-1155) e as interfaces de conformidade e identidade do padrão T-REX (ERC-3643). Em conjunto, esses componentes sustentam a emissão de ativos com controle de conformidade (compliance) e verificação de identidade on-chain.

A mensagem central para a diretoria é positiva: **nenhuma vulnerabilidade Crítica foi identificada, e a totalidade das vulnerabilidades de severidade Alta, Média e Baixa foi corrigida pela equipe da Axia e verificada pela HeimdallSec.** Os únicos itens ainda em aberto são de natureza **Informational / Gas** — recomendações de boas práticas e otimização que não representam risco de perda de fundos — e permanecem pendentes de implementação.

2. Postura de Risco Consolidada

Foram identificadas, ao longo dos 6 artefatos auditados, **37 descobertas**. Todas as de severidade Alta, Média e Baixa foram remediadas e verificadas; permanecem pendentes apenas as descobertas informativas / de otimização de gás.

Severidade	Quantidade	Resolvidas	Em Aberto	% Resolvido
Critical	0	0	0	—
High	5	5	0	100%
Medium	12	12	0	100%
Low	10	10	0	100%
Informational / Gas	10	0	10	0%
Total	**37**	**27**	**10**	**73%**

Os destaques da postura de risco são: ausência total de vulnerabilidades Críticas; **100% das vulnerabilidades High, Medium e Low corrigidas e verificadas**; e nenhum item de risco efetivo remanescente. Os 10 itens em aberto são exclusivamente **Informational / Gas**, sem impacto sobre a segurança de fundos, restando como recomendações de robustez e eficiência para uma próxima iteração de desenvolvimento.

3. Escopo Auditado

A tabela a seguir resume os 6 artefatos cobertos pelo engajamento. Todos os relatórios referem-se ao commit `9cd96c0b74c0c384d7e4daa934da7e5771494d7d` do repositório da Axia.

#	Artefato	Tipo / Padrão	Versão	Status da Auditoria
01	AxiaCompliantERC721	Token ERC-721 / ERC-3643 (T-REX para NFT)	2.0	Final (correções aplicadas; informativos pendentes)
02	IModularCompliance	Interface Solidity / ERC-3643	2.0	Final (correções aplicadas; informativos pendentes)

03	IIdentityRegistry	Interface Solidity / ERC-3643 (ONCHAINID)	2.0	Final (correções aplicadas; informativos pendentes)
05	WhitelabelNFTBurnable	Token ERC-721 (queima nativa)	1.0	Final (correções aplicadas; informativos pendentes)
06	ERC20TrancheToken	Token ERC-20 (tranches de crédito)	1.0	Final (correções aplicadas; informativos pendentes)
07	ERC1155ReceivableToken	Token ERC-1155 (recebíveis)	1.0	Final (correções aplicadas; informativos pendentes)

4. Consolidação das Descobertas por Artefato

A distribuição detalhada por artefato demonstra que todas as vulnerabilidades de risco efetivo (High/Medium/Low) foram resolvidas em cada relatório, restando apenas itens informativos. Os contratos de token principais (01 e 07) apresentaram o maior número de descobertas, coerente com sua maior superfície de código e complexidade funcional.

#	Artefato	Total	High	Medium	Low	Info	Resolvidas
01	AxiaCompliantERC721	8	1	2	3	2	6 de 8
02	IModularCompliance	3	0	2	0	1	2 de 3
03	IIdentityRegistry	5	1	2	1	1	4 de 5
05	WhitelabelNFTBurnable	7	1	1	3	2	5 de 7
06	ERC20TrancheToken	6	1	2	1	2	4 de 6
07	ERC1155ReceivableToken	8	1	3	2	2	6 de 8
Total		**37**	**5**	**12**	**10**	**10**	**27 de 37**

5. Itens em Aberto e Principais Remediações

5.1 Itens em Aberto (Informational / Gas)

Os **10 itens ainda em aberto são todos de severidade Informational / Gas**. Trata-se de recomendações de boas práticas de código, documentação (NatSpec) e otimização de consumo de gás. Nenhum deles representa risco de perda de fundos ou de contorno dos controles de conformidade. A HeimdallSec recomenda que sejam endereçados em uma próxima iteração de desenvolvimento, mas sua pendência não é impeditiva para a operação segura da plataforma.

5.2 Principais Remediações Aplicadas

Três frentes de correção de risco efetivo merecem destaque executivo. Primeiro, o **fortalecimento da governança administrativa** no AxiaCompliantERC721: o risco de centralização, em que o administrador poderia substituir os contratos de Identidade e Conformidade sem trava, foi endereçado com a migração do controle para carteira **multisig** e **timelock** em operações críticas. Segundo, a **correção da interface de conformidade** (IModularCompliance), com o versionamento e as validações recomendadas. Terceiro, a aplicação de **padrões de segurança nos contratos de token** (ERC-721, ERC-20 e ERC-1155): adesão ao Checks-Effects-Interactions

e proteção contra reentrância, validação de identidade on-chain e ordenação correta de eventos e chamadas externas.

6. Conclusão

O conjunto de contratos e interfaces da AxiaDigitalSolutions demonstra um nível de segurança sólido e um processo de remediação concluído nas frentes de risco efetivo: **não há descobertas Críticas, e 100% das vulnerabilidades High, Medium e Low foram corrigidas e verificadas.** Permanecem pendentes apenas 10 itens de natureza Informational / Gas, sem impacto sobre a segurança de fundos. Do ponto de vista de segurança, e considerando o escopo e o momento desta auditoria, a plataforma está bem posicionada para operar em produção, recomendando-se o tratamento dos itens informativos em iteração futura, a manutenção de um programa de Bug Bounty ativo e a reauditoria de quaisquer alterações relevantes de código.

7. Termo de Isenção de Responsabilidade (Disclaimer)

Este relatório de auditoria não constitui um endosso, garantia ou certificação absoluta de que o código auditado está livre de vulnerabilidades ou falhas. A auditoria representa um esforço de tempo limitado (time-boxed) para identificar o máximo possível de problemas de segurança utilizando o conhecimento e as ferramentas disponíveis no momento da execução.

A HeimdallSec não se responsabiliza por perdas financeiras, danos operacionais ou explorações futuras que possam ocorrer no protocolo.

gov.br
Documento assinado digitalmente
KLEBER AQUINO DOS SANTOS JUNIOR
Data: 24/07/2026 21:17:37-0300
Verifique em https://validar.iti.gov.br